保險業辦理資訊安全防護自律規範

金融監督管理委員會 102 年 12 月 26 日金管保綜字第 10200145480 號函准備查訂定
金融監督管理委員會 104 年 2 月 16 日金管保綜字第 10402562872 號函准備查修正
金融監督管理委員會 106 年 12 月 28 日金管保壽字第 10600961080 號函准備查修正
金融監督管理委員會 109 年 5 月 26 日金管保綜字第 1090419516 號函准備查修正
金融監督管理委員會 110 年 12 月 30 日金管保綜字第 1100495362 號函准備查修正
金融監督管理委員會 111 年 12 月 20 日金管保綜字第 1110466806 號函准備查修正
金融監督管理委員會 112 年 9 月 7 日金管保綜字第 1120493120 號函同意備查修正
金融監督管理委員會 113 年 7 月 18 日金管保綜字第 1130138369 號函同意備查修正

第 1 條

中華民國人壽保險商業同業公會與中華民國產物保險商業同業公會為督促會員公司資訊業務與相關資訊資產之安全，發揚自律精神，防範資訊處理作業過程發生影響資訊及系統機密性、完整性及可用性之安全事件，確保各會員公司資訊處理作業能安全有效地運作，特訂定本自律規範。

第 2 條

本自律規範用詞定義如下：

一、資訊資產：包含軟體、硬體、環境、文件、通訊、資料、人員等。

二、自攜裝置：係指非屬公司資產、透過該裝置以無線或有線通訊方式連接至會員公司內部網路，存取作業系統或檔案服務。

三、雲端服務：係指服務提供者以租借方式提供個人或企業得承租其網路、伺服器、儲存空間、基礎設施、資安設備、系統軟體、應用程式、分析與計算等資源，以達資源共享之服務。

第 3 條

各會員公司辦理資訊安全作業除應依據各該公司訂立之資安處理程序及其應注意事項外，並應符合依本自律規範辦理。

第 4 條

各會員公司辦理資訊安全作業，應至少遵循下列規定：

一、應要求所聘任之員工簽署資訊安全保密切結書、雇佣契約、工作手冊，明訂員工應遵守資訊安全保密協定。

二、有委外業務者，應於委外契約中明訂資訊安全保密協定。

三、應透過每年定期、適當之教育訓練或宣導，告知內部員工應遵循之資訊安全規範。

四、管理階層應督導員工遵循公司既定之資訊安全規範。

五、員工職務異動時，應依既定程序辦理資訊資產退回與存取權限之變更或取消。

六、應每年檢討資訊安全政策及資訊作業相關管理與操作規範，並於發生重大變

更（如新頒布法令法規）時審查，以持續確保其合宜性、適切性及有效性。

七、應依據作業流程，識別人員、表單、設備、軟體、系統等資產，建立資產清冊、網路架構圖、組織架構圖及負責人，並定期清點以維持其正確性。

八、應定義人員角色及責任並區隔相互衝突的角色。

第 4 條之 1

各會員公司之營運環境管理人員應遵循下列事項：

一、應建立人員之註冊、異動及撤銷註冊程序，用以配置適當之存取權限；人員離調職時應儘速移除權限。

二、應列管硬體設備、應用軟體、系統軟體之最高權限帳號及具程式異動、參數變更權限之帳號。

三、應確認人員之身分及存取權限，必要時得限定其使用之機器或網路位置（IP）。

四、人員超過一定時間未操作個人電腦時，應設定密碼啟動螢幕保護程式或登出系統。

五、登入作業系統進行系統異動或資料庫存取時，應留存操作紀錄，除利用系統代登外，應於使用後儘速變更密碼；但因故無法變更密碼者，應建立監控機制，避免未授權變更，並於使用後覆核其操作紀錄。

六、帳號應採一人一號管理，避免多人共用同一個帳號為原則，如有共用需求，申請及使用須有其他補強管控方式(如使用後更換密碼、代登入機制、密碼拆分保管等)，並留存操作紀錄且應能區分人員身分。

七、採用固定密碼進行身分確認者應符合下列要求：

(一)訂定密碼檢核邏輯。

(二)提供給人員使用之帳號於使用後三個月內應變更密碼。

(三)提供給系統使用之帳號應採取適當之管控措施（如限制人工登入、監控告警）。

八、加解密程式或具變更權限之公用程式（如資料庫工具程式）應列管並限制使用，防止未經授權存取並保留稽核軌跡。

九、最高權限帳號使用時應先取得權責主管或授權人員同意並保留稽核軌跡。

十、具最高權限帳號、特殊功能(如程式或軟體異動、參數或組態變更權限等)權限帳號應和日常維運用帳號區隔，並每月抽查使用結果，以防範未經授權使用；如為核心資通系統，應於該等帳號被使用後，覆核使用結果。

十一、 提供網際網路服務之伺服器及 AD(網域服務)主機，對於最高權限帳號及特殊功能權限帳號，應採雙因子認證或納入特權帳號管理系統強化授權及監控。

十二、 應針對第一類及第二類電腦系統依最小權限(least privilege)及僅知原則(need-to-know)配發權限予人員使用並定期審查帳號、權限之合理性及異常存取紀錄，以符合職務分工及牽制原則。

第 5 條

各會員公司應視資訊系統規模與架構，訂定資訊系統之範圍與相關作業規範：

一、訂定資訊系統開發及程式修改作業程序。

二、核心資訊系統應包括但不限於核保出單、保全（批改）、理賠、保費（收費）系統。

三、訂定核心資訊系統與第一類電腦系統中遠距服務、行動服務及電子商務資訊系統置換作業程序之項目：

(一)系統轉換前之準備工作：

1. 應建立架構審查機制，從應用程式、資料庫、資安、網路、平台、營運等面向進行評估，並評估一次過版或平行運轉可行性。

2. 應檢視相關設備容量，評估營運及業務需求所需備載容量。應建置擬真測試環境（如 UAT），測試新系統或功能相容於既有營運環境之架構、設備及參數。

3. 應訂定測試計劃與產出標準，依計劃以及影響範圍進行各項測試。測試應含功能測試 （如單元、整合、迴歸等），及非功能性測試（如相容性、尖峰量壓力測試及複合情境等）項目，並進行整體性演練。

4. 應進行上線變更審查及風險評估，辨識複雜度及影響範圍，並檢視測試個案及上線復原計畫之完整性，與建立多個檢核點及啟動復原之決策條件。

5. 應預留復原作業及上線驗證時間。

6. 應要求設備提供廠商與委外開發廠商於上線支援時，能緊急提供備品、問題查找及修改人力。

7. 應召開上線協調會議，安排工作項目並確保各項準備到位。

8. 應提前公告並進行教育訓練（含異常話術）。

(二)系統轉換作業：

1. 依上線計畫逐步執行，檢視每一個檢核點，必要時召開復原決策會議。

2. 執行系統及資料備份，以因應復原時所需。

3. 驗證各項變更作業，確保如預期結果。

4. 驗證各項資料內容，確保資料完整性。

5. 逐步啟動各項作業並監控網路及系統，確保提供足夠資源。

(三)系統轉換後之事件管理：

1. 持續系統監控，確保資料正確、功能正常、系統穩定。

2. 落實事故應變，以消費者權益及持續營運優先處理。

3. 集中管理問題並適時調配各單位資源。

4.追蹤問題原因，提出短中長期改善方案並持續追蹤。

第 6 條

各會員公司應建立資安防禦機制，並依據保險業辦理電腦系統資訊安全評估作業原則（如附件一）辦理各項資訊安全評估作業，以改善並提升網路與資訊系統安全防護能力。

第 7 條

各會員公司若有開發並提供行動裝置應用程式，應依據保險業提供行動裝置應用程式作業原則（如附件二）辦理，以確保行動應用程式（App ）安全防護能力，並保障消費者權益。

第 8 條

各會員公司若有運用新興科技（包含雲端服務、社群媒體、生物特徵資料及自攜裝置等），需依據保險業運用新興科技作業原則（如附件三）辦理，以建立完善之控管機制，降低新興科技之運用風險。

第 9 條

各會員公司若有運用物聯網設備，需依據保險業物聯網設備作業準則(如附件四）辦理，以強化物聯網設備之安全。

第 10 條

各會員公司辦理電子商務，應遵循下列事項：依據保險業經營電子商務自律規範及保險業電子商務身分驗證之資訊安全作業準則（如附件五）辦理，並建立安全有效之驗證機制，減少身分冒用及詐騙情事發生，以確保電子商務之資訊安全。

第 11 條

各會員公司應訂定設備報廢作業程序，報廢前應將機密性、敏感性資料及授權軟體予以移除、實施安全性覆寫或實體破壞，應確保報廢之電腦硬碟及儲存媒體儲存之資料不可還原，並留存報廢紀錄，若委託第三者銷毀時，應簽訂保密合約。

第 12 條

各會員公司於非公司職場實施異地辦公或遠端工作時，應評估相關作業風險，以強化遠端作業之安全：

一、針對營運環境調整、資料傳輸及加密機制、機敏資料防護、稽核軌跡留存、異常行為監控及對外遠端存取設備進行評估及強化，系統及設備如有重大漏洞應立即處理及因應，降低業務運作風險，確保整體保險系統穩定及安全。

二、針對使用之視訊會議系統、VPN 及 VDI 等設備，應訂定相關使用規範並落實各項安全管控作業。

三、應使用會員公司配發之裝置或設備，或使用資料不落地之機制，方得辦理遠端作業。

第 13 條

各會員公司應加強資訊安全事故管理。

各會員公司若發生資通安全事件，足以影響保險業信譽、或危及保險業正常營運、或金融秩序情事者，應依「保險業通報重大偶發事件之範圍申報程序及其他應遵循事項」規定辦理通報及回報各所屬公會，並採取適當處理措施，以控制資安事件影響範圍之擴大。

第 14 條

各會員公司若有建置可由外部 Internet 直接連線之網際網路應用系統及核心資訊系統，應定期辦理相關安全性檢測，相關資訊安全說明如下：

一、網際網路應用系統：

(一)應至少每季進行一次作業系統之弱點掃描，會員公司依掃描結果應進行風險評估，評估為高風險以上之弱點應於 2 個月內修補或完成補償性控制措施，評估為中、低風險應訂定適當措施及完成時間，執行矯正、紀錄處理情形並追蹤改善。

(二)新系統或系統功能首次上線前及至少每半年應針對異動程式進行程式碼掃描或黑箱測試，並針對其掃描或測試結果進行風險評估，及針對不同風險訂定適當措施及完成時間，執行矯正、記錄處理情形並追蹤改善；如無異動者則不在此限，但仍應參照「保險業電腦系統資訊安全評估作業原則」辦理電腦系統分類及評估週期相關作業。

二、核心資訊系統：

(一)應至少每半年進行一次作業系統之弱點掃描，會員公司依掃描結果應進行風險評估，評估為高風險以上之弱點應於 3 個月內修補或完成補償性控制措施，評估為中、低風險應訂定適當措施及完成時間，執行矯正、紀錄處理情形並追蹤改善。

(二)如為開放式系統，新系統或系統功能首次上線前及至少每半年應針對異動程式進行程式碼掃描或黑箱測試，並針對其掃描或測試結果進行風險評估，及針對不同風險訂定適當措施及完成時間，執行矯正、記錄處理情形並追蹤改善；如無異動者則不在此限，但仍應參照「保險業電腦系統資訊安全評估作業原則」辦理電腦系統分類及評估週期相關作業。

第 15 條

各會員公司辦理資訊系統維運時，應注意相關控制措施如下：

一、系統發展生命週期之維運（包含開發、測試）時，須注意版本控制與變更管理。

二、應定期審核資訊系統帳號之建立、修改及刪除。

三、應建立帳號管理機制，包含帳號之申請及刪除之程序。

四、應定期檢視防火牆規則，以確保現行控制之有效性。

第 16 條

各會員公司依保險業作業委託他人處理應注意事項辦理資訊系統作業委外，應於規劃及遴選階段，將資訊安全相關內容納入評估項目，以強化資訊安全。並遵循下列事項：

一、服務提供廠商應具備資訊安全相關認證或已有資通安全維護之相關措施。

二、審核作業委外廠商資格：

(一)各會員公司應制定有關審核廠商資格之內控機制，並就作業委外提供廠商進行評選審查作業。

(二)將資訊安全相關認證納入遴選項目，且應訂定內部程序，其至少包含作業委外廠商遴選機制、合約或協議簽訂、作業委外廠商管理要項、產品交付和驗收或維運等項目。

(三)各會員公司應將資訊安全或個人資料隱私管理相關認證納入資訊系統之作業委外廠商評估項目。

(四)各會員公司之資訊系統委外時，應依據委外廠商規模或作業特性，評估進行委外廠商監督。

三、作業委外廠商管理要項：

(一)應建立作業委外廠商管理規範，其內容應含作業委外廠商之人員管控，並建立適當檢驗機制，以確保管理機制有效落實。

(二)各會員公司之資訊系統委外廠商管理時，其管理項目應納入對委外廠商存取資訊之控管機制、對委外廠商服務之資訊安全管理措施查核機制、發生資安事故時委外廠商通知機制與應處時效要求、與委外廠商關係終止管理機制等項目。

(三)作業委外廠商進行軟、硬體維運時，應具備資通安全維護之措施。

(四)若作業委外內容有重大變更或重大事件時，應審查是否影響相關資訊安全管理制度或依循標準之要求並評估其風險，採取適當控制措施。

(五)作業委外廠商簽訂合約或協議，應遵循相關安全管理措施，其內容包含：

1. 服務供應廠商履行合約或協議時所提供軟體（或交付標的物）為交付產品，需具備合法性且不得違反智慧財產權之規定或侵害第三人合法權益。

2. 作業委外廠商進行資訊系統開發或維運時，若涉及客戶、員工個人資料，需考量具個人資料安全防範措施。

3. 應約定資安檢測與弱點修補之責任與時效要求。

4. 應訂定相關資訊安全管理責任。

5. 委外廠商交付之系統或程式，應確保無惡意程式及後門程式，或提供相關掃描報告。

(六)資訊系統作業委外終止或結束時，委外廠商應提供移轉服務，將留存

資料移回至各會員公司自行處理，並應刪除或銷毀全數資料，且提供刪除或銷毀之佐證資訊與紀錄。

四、委外稽核：

(一)定期進行查核作業。

(二)辦理作業委外稽核時，於簽訂之合約應載明保留相關之稽核權利，得自行或委託獨立單位對委外廠商監督及查核之權責行為。

(三)執行委外稽核作業後，應對稽核紀錄之文件進行複審及保存並由需求單位進行存查。

(四)提供委外稽核服務的廠商須通過政府資通安全建議的相關證照或可參照「保險業電腦系統資訊安全評估作業原則」之第柒點要求。

各會員公司辦理資訊系統委外作業項目，有涉及核心資訊系統者，除應依前項各款規定辦理外，應併同遵循「保險業核心資通系統作業委外資安注意事項」(如附件六)。

第 17 條

各會員公司電腦系統應加強日誌紀錄管理，並遵循下列事項：

一、應評估各系統產生之事件日誌紀錄(內容包含但不限於事件類型、發生時間、發生位置、使用者身分識別等資訊）之保留機制。

二、第一類、第二類電腦系統日誌應至少遵循下列規定辦理：

(一)紀錄至少需保留 180 天。如涉及個人資料之日誌紀錄者，保留期限應依個人資料保護法等相關規定辦理。

(二)事件日誌應設有存取限制，並應用適當方式確保完整性；另應依據事件日誌紀錄之儲存需求配置容量，且定期將日誌紀錄送至原系統外之其他系統進行集中管理，或建置日誌伺服器等相關方案滿足以上需求。

(三)應定期審查系統管理者活動以識別異常或潛在資安事件並保留紀錄，設定合適告警指標並定期檢討修訂；或將相關事件日誌納入資訊安全事件之監控管理機制範圍。

(四)應訂定日誌處理失效之告警及應處機制。

(五)系統內部時間應定期進行基準時間源進行同步。

第 18 條

各會員公司應強化對跨機構合作夥伴（含保險經紀人、代理人等合作關係）之資訊安全風險評估與措施，並遵循下列事項：

一、就保險業與跨機構合作夥伴共同使用之網際網路應用系統（如網路投保、網路要保等直接提供客戶自動化服務之系統），其系統管控機制應包括資料傳輸之保密方式、系統使用權限之區隔及系統帳號權限控管等相關資訊安全機制。

二、與跨機構合作夥伴合約簽訂時，應進行風險評估並規劃風險處置措施，並於雙方簽訂備忘錄或契約中載明相關要求，其內容需包含資訊安全及保戶個人資料保護相關條款、禁止多人共用同一帳號，以及相關業務往來之查核機制或控管措施，以確保資訊安全維護能力與水準。

三、提供跨機構合作夥伴資訊服務者，應採用雙因子驗證或相關身分驗證方式，並應定期辦理帳號密碼變更及帳號清查。

第 19 條

辦理網路安全管理時，應注意下列控制措施：

一、保險業對外提供之網站服務應建立 https 安全連線，以確保連線之機密性與完整性。

二、內部網路應依正式營運、測試、辦公室等使用目的區隔網段，網路區域間連接應進行控管，如以防火牆、虛擬區域網路 VLAN 或實體線路加以區隔；正式營運內應再依電腦系統分類或系統功能或服務特性進行網段區隔。

三、人員使用外部網路連線內部電腦系統時，應使用虛擬私有網路（VPN）或虛擬桌面（Virtual Desktop）之方式連線，並採多因子驗證，且須進行異常連線管理。

四、保險業網際網路應用系統，須建立防火牆（Firewall）、網站應用程式防火牆（WAF）防護機制、入侵偵測及防禦機制，並定期檢視其防護規則及參數設定。

五、員工電腦應建立上網行為管理措施，並啟用偵測惡意連線機制，確保阻斷外部惡意連線。

六、為強化正式伺服器主機的安全控管機制，於使用特權帳號進行正式伺服器主機管理作業時，應經主管審核後，透過特權帳號管理（PAM）或跳板機等管理系統或獨立的管制網段才可連線正式伺服器主機，並留存稽核軌跡，以確保正式伺服器網段的連線安全性。

七、應關閉非必要之網路服務，限制對網際網路非必要之連線。

第 20 條

各會員公司應將本自律規範內容，納入內稽內控制度中，並定期辦理查核。

第 21 條

各會員公司如有違反本自律規範之情事，經查證屬實者且違反情節較輕者，得先予書面糾正；如情節較重大者，提報經各所屬公會理事會通過後，處以新台幣伍萬元以上，貳拾萬元以下之罰款；前述處理情形並應於一個月內報主管機關。

第 22 條

本規範由中華民國人壽保險商業同業公會與中華民國產物保險商業同業公會共同訂定，經各該公會理事會決議通過報主管機關備查後施行，修正時亦同。